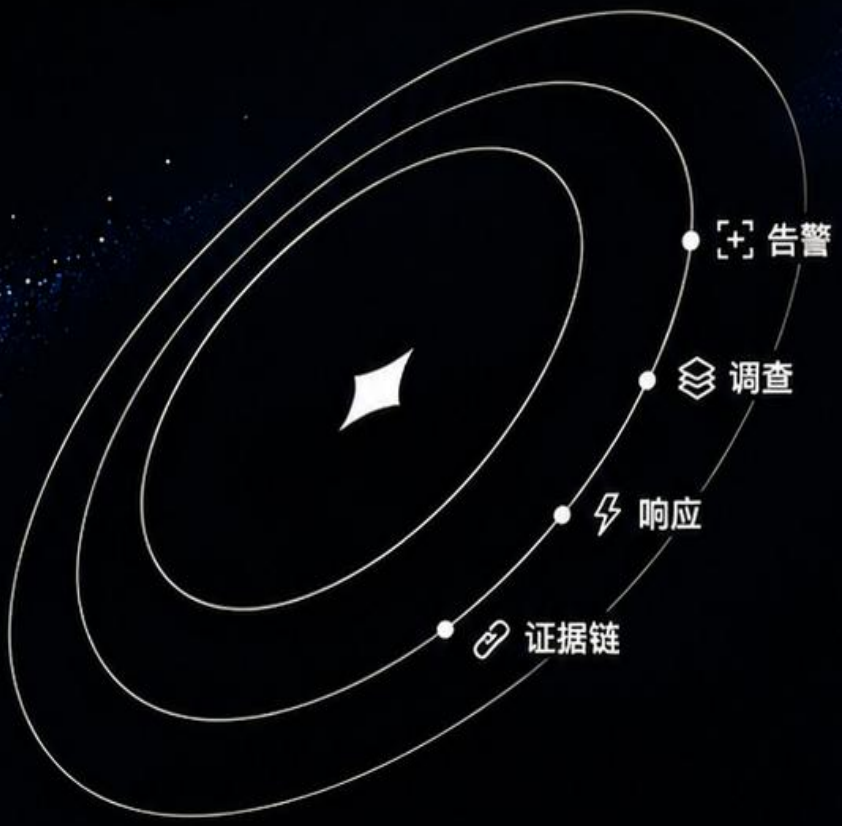
证链-EvidenceSOC

基于证据链与多智能体协作的安全告警调查与响应平台



摘要

随着网络攻击手段的不断演进和网络安全日志规模的持续增长，传统安全运营中心（Security Operations Center，SOC）在告警研判、威胁关联分析和安全事件响应等方面面临调查效率受限、证据关联复杂及人工分析成本较高等问题。对上述问题，本项目设计并实现了 EvidenceSOC——**基于证据链与多智能体协作的智能安全告警调查系统**，旨在将大语言模型的分析能力与安全事件证据管理相结合，构建具备证据可追溯性、过程可审计性和人工决策控制能力的智能化安全调查平台。

系统采用前后端分离架构，以 Next.js 和 FastAPI 构建应用服务，利用 PostgreSQL、pgvector 与 OpenSearch 实现安全事件存储、证据管理及日志检索。在人工智能技术方面，基于 LangGraph 构建由告警分诊、证据收集、威胁分析、攻击链重构、响应决策和效果验证组成的六角色协作流程，结合 DeepSeek 大语言模型、**MITREATT&CK 知识库**与 **RAG 混合检索技术**，实现安全事件的上下文分析与攻击行为关联。同时，通过**自建只读 MCP 工具**、EvidenceID 引用约束、结构化输出校验及有限工具调用机制，约束智能体的操作范围，并在证据不足时保留未知判断。

在安全响应方面，系统设计了基于真实人工审批的模拟处置机制，通过响应计划版本绑定、审批状态校验及执行后证据验证，形成从告警发现到模拟响应效果评估的可审计调查流程。实验方面，项目采用 **AIT 与 DEDALE 数据集**，完成原始 704 组案例实验及新增 176 组独立工程回归，**七个关键模块的语句覆盖率为 91.31% - 96.26%**，连续三轮生产浏览器测试各 62 项全部通过。实验表明，系统具备可审计的调查流程和一定的工程可靠性，同时固定版本已完成 909 项后端测试及三轮各 62 项浏览器测试。

本项目探索了大语言模型、多智能体编排、检索增强生成与证据约束机制在网络安全运营场景中的集成应用，为构建可追溯、可审计、具备人工监督能力的智能安全告警调查系统提供了工程实践参考。

关键词：安全运营中心；前后端分离架构；多智能体协作；LangGraph；RAG 混合检索；证据链；MCP；智能告警调查

目录

第一章项目概述 6
1.1 项目背景 6
1.2 项目目标 6
1.3 项目价值 7
1.3.1 技术研究价值 7
1.3.2 实际应用价值 7
1.4 项目创新点 7
1.4.1 技术创新点 7
1.4.2 应用创新点 7
第二章需求分析 8
2.1 需求分析概述 8
2.2 功能性需求分析 8
2.3 非功能性需求分析 9
第三章系统架构设计 9
3.1 系统总体架构 9
3.2 系统技术栈及选型 11
3.3 核心模块与数据流设计 11
3.3.1 日志接入与证据管理模块 11
3.3.2 智能调查任务数据流 12
第四章 AI 技术方案 13
4.1AI 技术方案概述 13
4.2 大语言模型选型与集成方案 13
4.2.1 大语言模型选型依据 13
4.3 基于 LangGraph 的多智能体协作方案 14
4.3.1 多角色协作设计 14
4.4 基于 ATT&CK 的 RAG 知识增强方案 14
4.4.1 知识来源与向量化 14
4.4.2 混合检索机制 15

4.5AI 优化策略与可靠性设计 16
4.5.1 证据约束与无依据结论控制 16
4.5.2 有界工具调用与自主取证控制 16
4.5.3 结构化校验与安全防护 17
第五章核心功能实现 17
5.1 安全日志接入与证据管理 17
5.1.1 安全日志接入与事件检索 17
5.2 六角色智能调查流程实现 17
5.2.1 调查任务创建与执行管理 17
5.2.2 六角色节点与条件路由 18
5.3 攻击链构建与可视化实现 18
5.3.1 攻击链数据组织 18
5.3.2 攻击链可视化交互 19
5.5 前端调查工作台与状态交互 19
5.5.1 调查工作台与证据交互 19
5.5.2SSE 实时更新与状态恢复 19
第六章测试与实验评估 20
6.1 测试目标与评估方案 20
6.2 实验数据集与对照方案 20
6.2.1 数据集构建与选择 20
6.2.2 对照组与消融实验设计 21
6.2.3 评价指标 21
6.3 原正式实验结果与分析 22
6.3.1 实验完成情况 22
6.3.2 分类性能对比 22
6.4 独立工程回归结果 24
6.4.1 工程回归实施情况 24
6.4.2 回归分类结果 24
6.5 人工复核与证据质量评价 25
6.5.1 人工复核方案 25

6.5.2 证据支持程度 25
6.6 系统工程测试与部署验证..... 26
6.6.1 功能与安全测试 26
6.6.2 前端交互与状态恢复测试 27
6.6.3 系统性能与部署状态 27
第七章总结与展望 27
7.1 项目工作总结..... 27
7.2 当前局限性 28
7.3 未来发展方向..... 28

第一章项目概述

1.1 项目背景

随着网络信息系统规模不断扩大和网络攻击手段日趋复杂，网络环境中全设备产生的告警与日志数量持续增长。传统安全运营中心（Security Operations Center，SOC）在威胁研判过程中，通常需要人工关联不同来源的日志，分析时间、攻击来源、目标资产等行为，存在调查过程繁琐、证据关联复杂、分析结果依赖人员经验等问题。面对具有多个攻击阶段的安全事件时，单条告警难以反映完整的攻击上下文。

大语言模型（Large Language Model，LLM）在自然语言理解、复杂任务分析等方面具有一定优势，为网络安全告警调查提供了新的技术思路。然而，模型可能依据不完整的信息生成缺乏事实支持的结论，可能将安全知识库中的一般性攻击描述误认为当前环境中实际发生的行为，因此，如何约束模型的证据来源、工具权限和决策过程，成为智能安全运营系统需要解决的重要问题。

基于上述背景，本项目设计并实现了 Evidence SOC——基于证据链与多智能体协作的智能安全告警调查系统，系统融合大语言模型、LangGraph 多角色协作、检索增强生成（RAG）与结构化证据管理技术，构建以客观证据为基础、以智能分析为辅助、以人工监督为安全边界的告警调查平台。

1.2 项目目标

EvidenceSOC 以“证据驱动、流程可控、结论可追溯、响应可审计”旨在辅助安全分析人员完成从告警接入、证据收集到威胁分析和响应验证的调查流程。项目主要目标包括以下四个方面。

（1）实现安全事件的统一接入与管理。

对多来源安全日志进行解析、规范化与持久化处理，建立安全事件、告警和调查案件之间的关联关系，为证据检索与事件分析提供统一的数据基础。

（2）构建多角色协作的自动化调查流程。

基于 LangGraph 设计包含告警分诊、证据收集、威胁分析、攻击链重构、响应决策和效果验证的六角色工作流，统一状态管理与条件路由，实现任务的有序执行。

（3）实现安全知识增强与受控工具调用。

结合 MITRE ATT&CK 知识库和 RAG 混合检索技术，为模型提供攻击技术背景；利用 EvidenceID 证据引用机制、自建只读 MCP 工具及结构化校验，限制模型的调查权限，提高分析结论的可追溯性。

（4）**建立人工监督下的模拟响应与验证机制。**

生成包含操作目标、风险影响、回滚措施及验证要求的结构化响应方案，经真实人工审批后执行安全模拟，并结合后续观察结果进行效果验证，保留完整审计记录。

1.3 项目价值

1.3.1 技术研究价值

本项目探索大语言模型、多角色任务编排与证据约束机制在网络安全调查中的协同应用。通过固定工作流、有限工具调用、结构化输出及证据完整性校验，将模型分析与客观事件记录建立可追溯关联。同时，区分安全知识背景与真实案件证据，为研究智能体调查过程的可靠性、可解释性及安全边界提供工程实践参考。

1.3.2 实际应用价值

EvidenceSOC 面向安全运营人员的告警研判场景，将日志检索、证据关联、威胁分析、攻击链展示与模拟响应整合至统一调查工作台。系统支持调查状态展示和历史记录追溯，并在证据不足时保留未知判断或人工复核状态，为安全分析人员提供结构化、可审查的调查辅助工具。

1.4 项目创新点

1.4.1 技术创新点

（1）**证据驱动的智能调查机制。**将 EvidenceID 引用约束与双存储内容完整性校验相结合，使关键事实性结论能够关联当前案件的合法证据，并区分引用有效性与事实语义支持程度。

（2）**有界多角色协作与受控取证机制。**采用 LangGraph 固定六角色工作流，结合 MCP 工具、条件路由和受控补证机制，在提供自主调查能力的同时约束模型执行范围。

（3）**知识与事实分离的混合检索机制。**将 ATT&CK 攻击技术知识作为分析辅助背景，与实际事件证据独立管理，通过关键词和向量混合检索提供知识支持，避免直接将检索知识作为攻击发生的证明。

1.4.2 应用创新点

（1）**面向安全调查的证据可视化交互。**将六角色调查进度、攻击链结构、证据详情及运行记录整合至可视化工作台，使调查结果能够关联具体证据来源。

（2）**人工审批与模拟响应相结合。**通过响应计划版本及哈希绑定、真实人工审批和确定性验证机制，建立受控的模拟处置流程，避免模型直接执行真实封禁、隔离或账户停用操作。

第二章需求分析

2.1 需求分析概述

Evidence SOC（证链）面向安全运营中心的告警调查场景，主要服务于需要进行安全事件研判、日志关联分析、攻击行为识别及响应方案审查的安全分析人员。

传统安全告警系统通常侧重事件记录、条件检索与告警展示，而复杂攻击事件往往涉及多个日志来源和关联行为，需要进一步确认事件背景、提取有效证据并判断攻击性质。由此本系统不仅具备基础日志管理能力，还支持多角色协作调查、证据完整性校验、攻击链可视化、人工审批及调查过程审计等完整业务流程。

2.2 功能性需求分析

功能模块	具体需求
安全日志与告警管理	支持安全日志解析、字段规范化、事件持久化及检索索引管理，提供告警查询、事件关联与调查启动功能。
多角色智能调查	基于六角色工作流完成告警分诊、证据收集、威胁分析、攻击链重构、响应决策和效果验证，并根据调查结果执行条件路由。
证据管理与校验	为合法证据分配 Evidence ID，记录案件归属、来源、时间及内容哈希，验证证据完整性与模型引用有效性。
安全知识检索	基于 MITRE ATT&CK 知识库提供攻击技术查询，结合关键词与向量混合检索辅助分析，并区分知识背景与案件事实。
攻击链重构与展示	根据有效证据组织攻击步骤及阶段关系，通过图形化界面展示攻击行为、证据引用与不确定关系。
人工审批与模拟响应	生成包含动作目标、风险影响、回滚措施及验证条件的响应方案，经实际人工批准后进行安全模拟和效果验证。
调查状态与审计管理	展示调查进度、角色运行记录、证据详情与响应状态，支持状态持久化、SSE 事件更新和异常连接恢复。

2.3 非功能性需求分析

除业务功能外，EvidenceSOC 还需要满足安全性、可靠性、可追溯性、可维护性及资源可控性等要求。

需求类别	具体要求
安全性	模型仅访问授权工具；查询范围绑定当前案件；响应必须人工批准
可靠性	任务状态持久化；处理连接中断、重复请求及部分依赖故障
可追溯性	保留 EvidenceID、来源、时间、哈希和调查过程记录
可解释性	区分观察事实、模型推断、未知判断和知识背景
可维护性	前后端分层、统一数据模型、结构化接口与模块化服务
资源可控性	限制模型及工具调用次数，保留物理尝试、失败与未知用量
可测试性	支持 fixture 与真实模型模式，建立独立评估和测试流程
可扩展性	通过模块化设计，为未来接入更多日志来源与分析能力提供基础

第三章系统架构设计

3.1 系统总体架构

EvidenceSOC 采用前后端分离、模块化服务和有状态智能体编排相结合的系统架构，以安全事件数据为基础，以 LangGraph 六角色调查工作流为核心，通过 API 服务、受限 MCP 工具、检索增强生成及持久化数据管理，实现从告警接入、证据收集到威胁分析和模拟响应验证的业务流程。

系统总体划分为用户交互层、业务服务层、智能调查层、工具与知识服务层以及数据持久化层五个部分。



（1）用户交互层

基于 Next.js 和 React 构建 Web 应用，提供安全告警管理、调查任务启动、智能体执行状态展示、攻击链可视化、证据详情查看及响应方案审批等交互功能。

（2）业务服务层

采用 FastAPI 构建后端 API 服务，负责处理前端请求、验证访问参数、管理调查任务与响应审批，并向前端提供持久化状态快照和事件流。

（3）智能调查层

基于 LangGraph 构建固定六角色工作流，组织告警分诊、证据收集、威胁分析、攻击链重构、响应决策和效果验证，并根据调查结果执行条件路由、人工审批中断及状态恢复。

（4）工具与知识服务层

通过自建只读 MCP 服务向智能体提供受限事件查询和 ATT&CK 知识检索能力，结合 PostgreSQL 全文检索与 pgvector 语义检索，为分析提供合法证据和安全知识背景。

（5）数据持久化层

使用 PostgreSQL 保存业务数据、证据、调查状态及审计记录，使用 OpenSearch 支持安全日志检索，并通过 PostgreSQL 检查点保存工作流状态，为证据追溯与任务恢复提供数据基础。

3.2 系统技术栈及选型

技术组件	采用技术	主要作用及选型理由
前端框架	Next.js、React	组件化开发，支持复杂调查工作台
UI 可视化	AntDesign、ReactFlow、ECharts	提供规范化交互组件，展示攻击链及安全分析结果
后端框架	FastAPI，	提供异步 API 和结构化请求校验
智能体编排	LangGraph	支持有状态工作流、条件路由及审批中断
大语言模型	DeepSeek	提供威胁分析和结构化结果生成能力
工具协议	MCP	实现受限工具调用与工具能力管理
关系数据库	PostgreSQL	存储业务数据、证据和调查状态
向量检索	pgvector	实现知识向量相似度检索
日志检索	OpenSearch	支持安全事件查询
实时更新	Server-SentEvents（SSE）	向页面推送调查进度及状态变化

3.3 核心模块与数据流设计

3.3.1 日志接入与证据管理模块

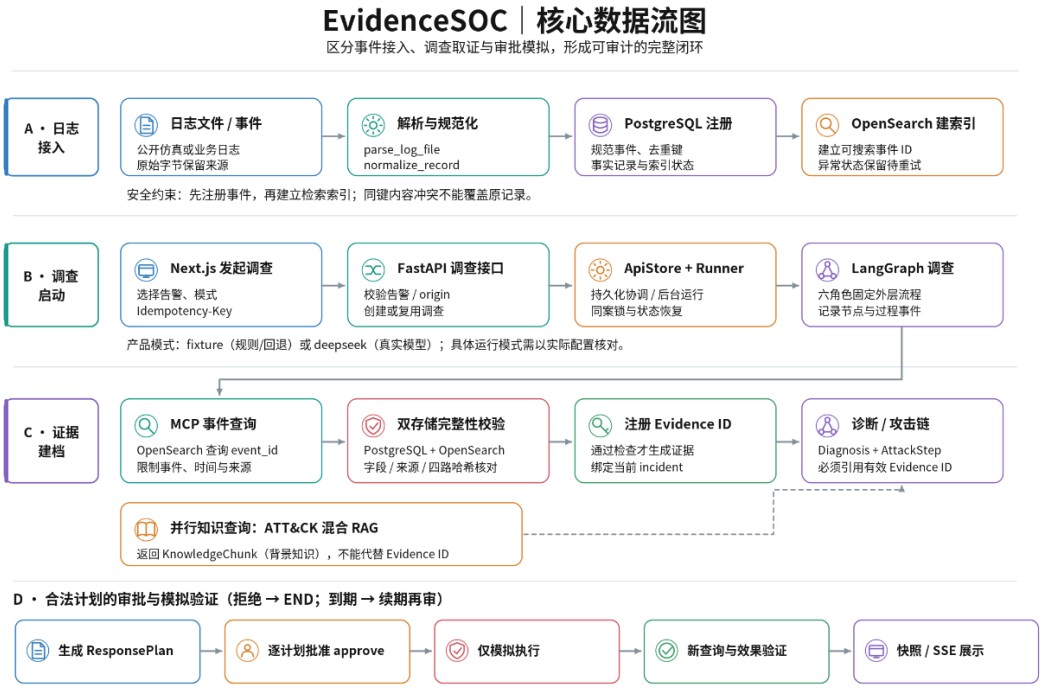
安全日志首先由 IngestionService 完成解析和字段规范化，转换为统一的 SecurityEvent 对象。系统将事件注册至 PostgreSQL，再写入 OpenSearch 建立检索索引；对于索引失败或重复事件保留相应处理状态，避免直接覆盖原始数据。

在调查取证阶段，系统通过 OpenSearch 查询候选事件标识，再由 EvidenceService 读取 PostgreSQL 和 OpenSearch 中的对应记录，核对事件身份、规范化字段及内容哈希。校验通过后，生成具有案件归属、来源和时间信息的 EvidenceItem，供后续智能体引用。该数据流将日志检索与证据可信性校验分离，避免将搜索结果直接视为合法调查证据。

3.3.2 智能调查任务数据流

用户从告警页面发起调查后，前端通过固定 API 代理向 FastAPI 提交告警标识、运行模式及幂等请求标识。后端完成参数和会话校验后创建调查任务，并由 InvestigationRunner 协调 LangGraph 工作流执行。

工作流首先加载案件上下文，再通过受限 MCP 工具获取事件证据和 ATT&CK 知识。威胁分析模块依据有效证据生成结构化诊断，随后根据分析结果选择相应处理路径。对于正常事件，调查可直接结束；对于证据不足的事件，最多进行一次受控补证；对于具有合法攻击诊断的事件，进入攻击链重构与响应方案生成阶段。响应方案经过真实人工审批后，系统仅执行模拟动作，并通过后续观察结果进行确定性验证。



第四章 AI 技术方案

4.1AI 技术方案概述

Evidence SOC，采用大语言模型、多智能体任务编排、检索增强生成（Retrieval-Augmented Generation，RAG）和模型上下文协议（Model Context Protocol，MCP）相结合的技术，构建以安全事件证据为基础的智能告警调查流程。

系统以 LangGraph 管理六角色调查任务，通过 DeepSeek 完成威胁分析、攻击链重构和响应方案生成，利用 RAG 提供攻击技术知识，并通过自建 MCP 工具实现受控取证。同时，将证据完整性、工具权限、结构化校验和人工审批交由确定性程序控制，避免模型直接决定安全敏感操作。

4.2 大语言模型选型与集成方案

4.2.1 大语言模型选型依据

安全告警调查涉及日志语义理解、跨事件关联、攻击行为解释等任务，因此要求模型能够处理安全领域上下文，并与外部工具和业务数据模型协同工作。

EvidenceSOC 选择 DeepSeek 作为真实模型模式的分析接口，主要基于以下考虑。

（1）支持结构化分析输出。

模型能够通过结构化输出接口生成符合预定义数据模型的诊断、攻击步骤和响应建议，便于后端程序进行字段及业务规则校验。

（2）能够处理包含安全术语的上下文。

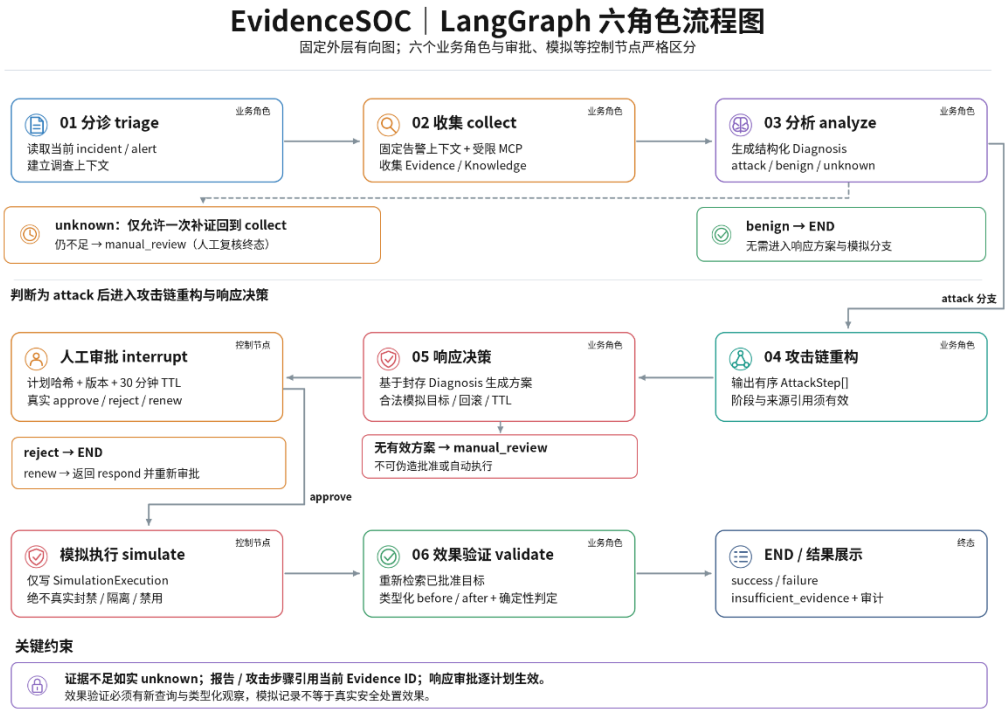
模型能够结合日志事件、告警上下文和 ATT&CK 知识，辅助分析异常行为及潜在攻击关系，并按照系统约束区分观察事实与推测性解释。

（3）能够与 Python 智能体框架集成。

模型服务可通过 OpenAI 兼容接口与 Python 应用集成，配合 LangChain、Pydantic 和 LangGraph 构建有状态的智能调查流程。

4.3 基于 LangGraph 的多智能体协作方案

4.3.1 多角色协作设计



EvidenceSOC 使用 LangGraph 构建固定的六角色调查工作流，将复杂安全告警调查划分为告警分诊（Triage）、证据收集（Collect）、威胁分析（Analyze）、攻击链重构（Reconstruct）、响应决策（Respond）和效果验证（Validate）六个阶段。

各角色通过统一调查状态传递必要信息，并由工作流管理执行顺序、条件分支和状态恢复。其中，分诊主要负责加载案件数据，收集角色使用受限工具获取证据，分析、重构和响应角色利用模型生成结构化结果，验证角色主要执行确定性逻辑。六角色属于具有不同职责的业务处理节点，不代表系统部署了六个完全独立运行的大语言模型实例。

4.4 基于 ATT&CK 的 RAG 知识增强方案

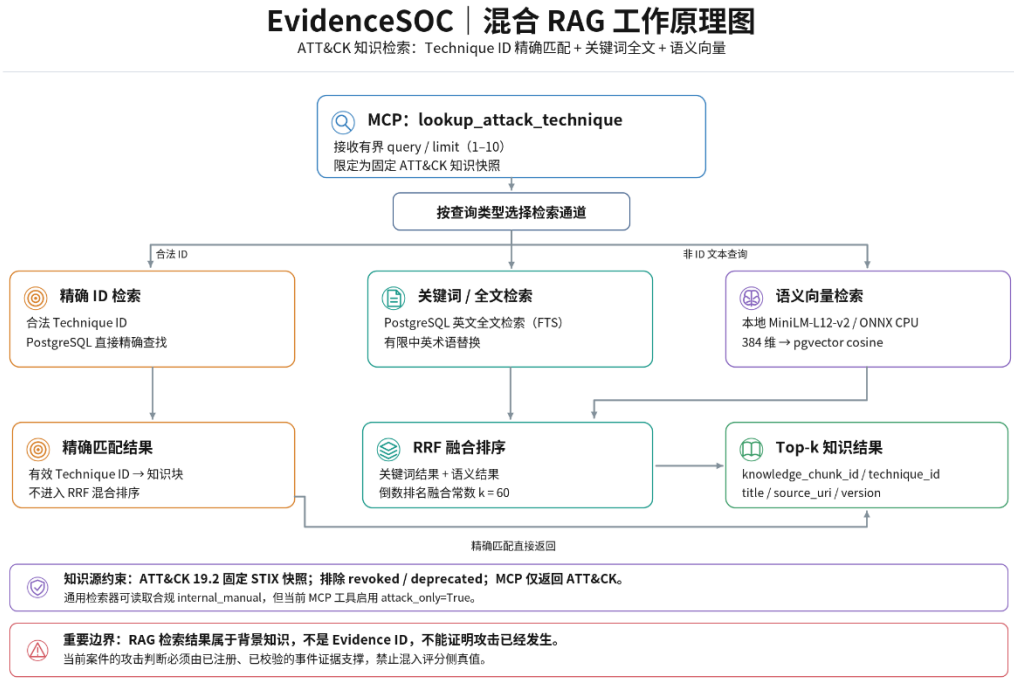
4.4.1 知识来源与向量化

为增强模型对攻击行为和技术术语的理解，系统引入 MITRE ATT&CK 知识库，并采用固定的 ATT&CK 19.2 知识快照作为攻击技术背景来源。

知识预处理包括来源校验、有效技术条目筛选、文本分块、向量生成和持久化存储。系统使用固定版本的多语言 MiniLM-L12-v2 嵌入模型，通过本地 fastembed 与

ONNX 环境生成 384 维向量，并利用 PostgreSQL 和 pgvector 进行存储与检索。原正式评估登记了 997 个合格知识块。知识库提供攻击技术解释与背景信息，但不直接证明当前案件中已经发生相应攻击行为。

4.4.2 混合检索机制



为兼顾攻击技术编号、关键词和自然语言查询，系统采用精确匹配、全文检索和向量相似度检索相结合的混合检索方案。

对于合法 ATT&CK 技术编号，系统优先执行精确查询；对于一般文本查询，结合 PostgreSQL 全文检索与 pgvector 向量检索获取候选知识，再使用倒数排名融合（Reciprocal Rank Fusion，RRF）整合不同检索通道的结果。

RRF 的基本形式如下：

$$RRF(d) = \Sigma \ 1 \ / \ (k + rank_i(d))$$

其中，d 表示候选文档，$rank_i(d)$ 表示该文档在第 i 个检索通道中的排序名次，k 为排名平滑常数。本项目实现使用 k=60。

通过上述方式，系统能够综合利用精确匹配、关键词检索和语义检索结果，降低对单一检索方式的依赖。

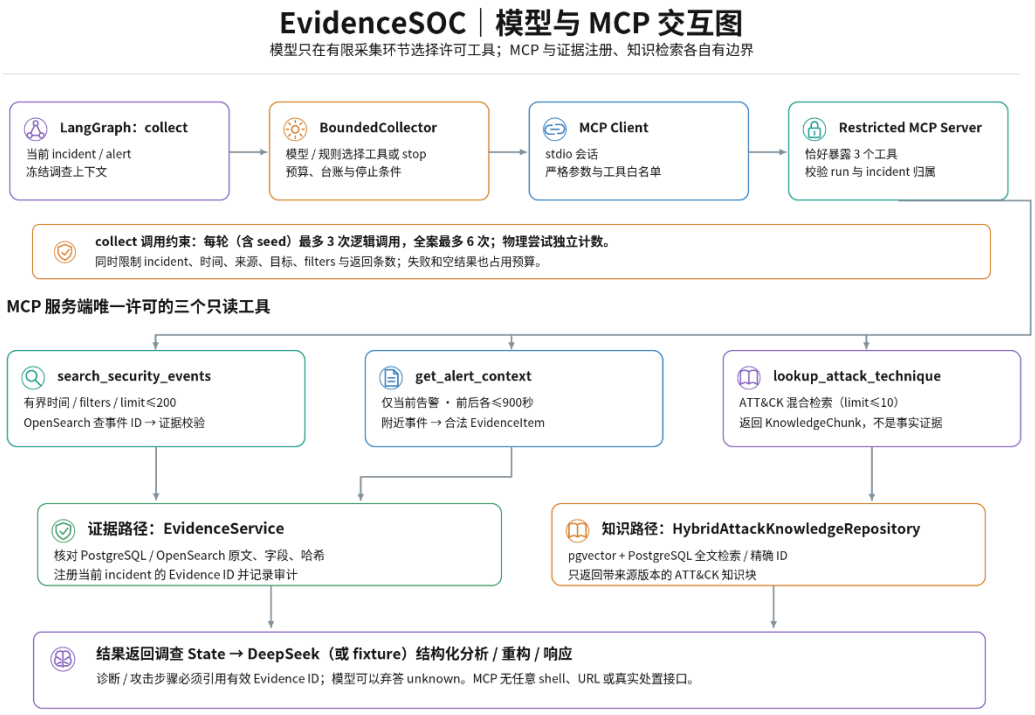
4.5AI 优化策略与可靠性设计

4.5.1 证据约束与无依据结论控制

对大语言模型可能生成无事实支持结论的问题，系统建立 EvidenceID 证据引用机制。安全事件在通过来源、归属及完整性校验后，才能作为合法证据进入调查流程。

模型输出的关键事实性判断必须关联当前案件中的有效 EvidenceID，系统进一步验证引用结构及所属关系。同时，将实际事件证据与 ATT&CK 知识背景分开管理，避免模型仅依据通用攻击知识推断当前环境中发生了特定行为。证据不足的情况，系统允许返回 unknown，而不是强制生成确定性攻击结论。该机制主要用于提高调查过程的可追溯性，不意味着能够完全消除模型的语义判断错误。

4.5.2 有界工具调用与自主取证控制



为避免模型产生无限查询或越权操作，系统通过自建只读 MCP 服务限定外部工具能力，仅开放三个工具：

search_security_events：查询当前案件范围内的安全事件；

get_alert_context：获取当前告警附近的事件上下文；

lookup_attack_technique：检索 ATT&CK 攻击技术知识。

工具调用必须经过名称、参数、案件归属和时间范围校验。证据收集阶段每轮最多执行 3 次、单次调查累计最多 6 次逻辑工具调用，固定初始查询、失败调用和空结

果均计入相应预算。系统还设置无新证据停止条件与一次补证回退机制，在保持有限自主取证能力的同时控制调用规模与调查范围。

4.5.3 结构化校验与安全防护

系统通过角色专用的数据结构、Pydantic 校验及服务端业务规则，对模型生成结果进行多层约束，包括证据引用、攻击步骤顺序、响应动作类型及操作目标合法性。

对于日志和知识检索返回的外部文本，系统将其视为不可信输入，避免其中的指令性内容直接改变工具权限或调查流程。模型不能访问任意命令执行、文件读取或外部 URL 请求工具，响应方案必须经过独立校验与真实人工审批。

上述措施用于降低模型输出不确定性和不可信输入造成的工程风险，但不代表系统能够抵御所有提示注入或模型错误。

第五章核心功能实现

5.1 安全日志接入与证据管理

5.1.1 安全日志接入与事件检索

EvidenceSOC 通过日志接入服务实现安全事件的解析、规范化和持久化管理。系统利用 IngestionService 调用日志解析组件，将原始记录转换为统一的 SecurityEvent 对象，保留事件时间、来源、目标及相关上下文信息。

在数据存储阶段，系统首先向 PostgreSQL 注册安全事件，再向 OpenSearch 建立检索索引。对于重复记录、内容冲突及索引失败，系统保留相应处理状态，并提供待索引事件的恢复机制，避免异常数据被静默覆盖。调查过程中，安全事件查询通过受限 MCP 工具执行。工具根据当前案件的时间、来源及目标范围检索候选事件，再交由证据服务进行验证，防止无关事件直接进入调查上下文。

5.2 六角色智能调查流程实现

5.2.1 调查任务创建与执行管理

用户从告警列表选择目标告警后，通过前端向 POST/api/v1/investigations 接口提交告警标识、运行模式及幂等请求标识。FastAPI 完成参数、会话和来源校验后，由 ApiStore 创建持久化调查记录，并交由 InvestigationRunner 启动后台工作流。

调查执行采用 LangGraph 组织六角色节点，共享受约束的调查状态，并记录执行状态、证据引用及必要审计信息。系统通过 PostgreSQL 检查点与持久化协调机制支持工作流恢复，降低页面连接中断、服务重启或重复请求对调查状态造成的影响。

5.2.2 六角色节点与条件路由

六角色分别负责案件初始化、受限取证、威胁诊断、攻击链重构、响应方案生成和效果验证，具体实现如下。

调查角色	核心实现	主要输出
Triage	加载当前告警和案件上下文，建立调查范围	初始调查状态
Collect	通过 BoundedCollector 执行合法证据及知识查询	EvidenceItem
Analyze	利用结构化模型分析证据并验证引用	Diagnosis
Reconstruct	组织有证据支持的攻击步骤与阶段关系	AttackStep、攻击链
Respond	生成并校验符合约束的模拟响应计划	ResponsePlan
Validate	核对审批、模拟执行和新观察结果	ValidationResult

工作流根据结果执行条件路由：正常事件可以结束调查；证据不足时最多进行一次受控补证，仍无法判断则进入人工复核；明确攻击且满足条件时，继续进行攻击链重构和响应方案生成。模型输出需通过 Pydantic 结构校验和业务规则检查。对于不满足要求的内容，系统执行失败、回退或人工复核处理，避免无效结果进入后续流程。

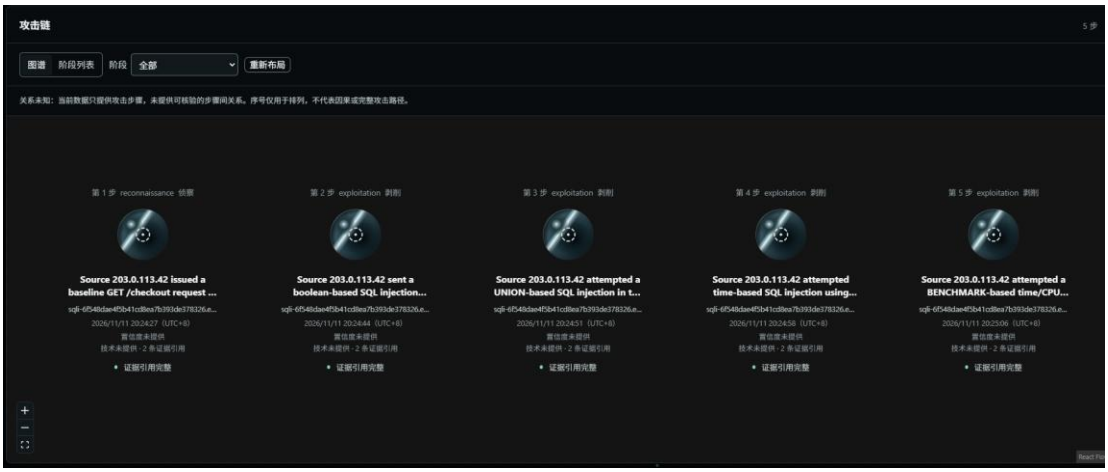
5.3 攻击链构建与可视化实现

5.3.1 攻击链数据组织

攻击链重构模块根据合法诊断与已注册证据生成结构化攻击步骤。各步骤通过 AttackStep 对象记录行为描述、阶段信息和 Evidence ID 引用，并检查步骤编号、唯一标识及数据结构的合法性。

系统仅根据已获取的证据组织可观察的攻击行为，不为缺失阶段自动补造事件。对于尚不能确定的关联关系，保留候选或不确定状态，避免将推测性攻击路径作为已验证事实。

5.3.2 攻击链可视化交互



前端采用 React Flow 构建二维攻击链图谱，通过节点展示攻击步骤，并根据后端提供的关系数据绘制连接线。系统区分时间先后关系、待证实因果关系和一般关联关系，使用不同的线型及方向表达其含义。

工作台采用球形视觉样式展示攻击步骤，结合 Dagre 完成节点布局。球形效果属于二维节点的视觉设计；图谱布局顺序也不作为真实攻击因果关系的证明。用户选择攻击步骤后，可以通过关联证据入口查看对应的 Evidence ID、事件摘要和可访问的证据详情，实现从攻击链展示到原始事件依据的追溯。

5.5 前端调查工作台与状态交互

5.5.1 调查工作台与证据交互

EvidenceSOC 基于 Next.js、React 和 Ant Design 构建安全调查工作台，提供告警管理、案件详情、六角色进度、攻击链及响应方案等功能。

当前前端采用中文导航与深色主题，调查工作台使用两列布局，并通过右侧抽屉按需展示证据详情和角色运行记录。证据界面保留分页查询、受控原文访问和完整性状态提示；运行记录展示实际角色执行信息，不为缺失的记录生成虚构内容。

5.5.2SSE 实时更新与状态恢复

系统通过 Server-Sent Events（SSE）向前端提供调查状态更新。页面首先读取包含版本号与事件游标的持久化快照，再订阅后续事件。

后端提供持久化事件读取、事件游标续传及状态重置机制；前端在连接断开、消息缺口或状态过期时重新获取快照，并执行有界重连，避免使用不连续的调查数据。

调查任务由后端独立协调，浏览器关闭或 SSE 连接断开不会自动取消已创建的后台任务。前端仅提供展示与交互入口，真正的证据校验、审批有效性和模拟执行权限由后端控制。

第六章测试与实验评估

6.1 测试目标与评估方案

为评估 EvidenceSOC 在安全告警调查场景中的功能完整性、智能分析效果、证据可信度及工程可靠性，项目从模型实验评估、人工证据复核和系统工程测试三个方面开展验证。模型实验主要比较不同智能调查方案在威胁分类、回答覆盖率和资源消耗等方面的表现；人工复核用于判断模型报告中的事实性主张是否获得证据支持；工程测试则重点验证系统接口、状态恢复、工具权限及模拟响应等机制的可靠性。

实验采用 AIT Log Data Set V2.1 与 DEDALE V2.1 两个安全日志数据集开展实验，以评估系统在不同日志场景下的智能告警调查能力。

AIT 数据集包含多个独立网络场景中的安全日志及攻击标注，涉及 Web 攻击、远程命令执行、权限提升和数据窃取等攻击行为，适用于多类型攻击识别与攻击阶段分析。项目采用按场景隔离的划分方式，最终选取 22 个冻结测试案例，其中 11 个攻击案例、11 个正常案例，以降低关联日志跨集合造成的数据泄漏风险。

DEDALE 数据集包含仿真网络环境中采集的主机安全日志及攻击活动标注，具有时间跨度较长、日志规模较大和攻击活动相互关联等特点，适用于安全事件关联与攻击检测研究。项目采用时间隔离方式，将前两周数据用于正常背景校准，后两周作为冻结测试区间，最终选取 66 个案例，其中 28 个攻击案例、38 个正常案例。

6.2 实验数据集与对照方案

6.2.1 数据集构建与选择

本项目选用 AITLogDataSetV2.1 与 DEDALEV2.1 作为主要实验数据来源，分别用于评估不同日志场景下的安全告警调查能力。

AIT 数据集采用按场景隔离的划分方式，开发、验证和测试场景相互区分，避免关联日志窗口跨越不同数据划分。最终冻结 22 个测试案例，其中包含 11 个攻击案例和 11 个正常案例。DEDALE 数据集采用时间隔离方案，将前两周数据用于正常背景校准，后两周作为冻结测试区间。最终选取 66 个测试案例，其中 28 个攻击案例、38 个正常

案例。该数据集属于单一攻击活动背景下的仿真日志，不等同于真实企业环境中的独立攻击样本。

实验数据集与案例规模

数据集	测试案例	攻击/正常	原正式实验	新工程回归
AIT V2.1	22	11/11	176 行	44 行
DEDALE V2.1	66	28/38	528 行	132 行
合计	88	39/49	704 行	176 行

实验仅使用冻结的案例选择与输入条件，不根据测试得分重新挑选案例或修改标准答案。两个数据集独立计算指标，以避免不同类别标注范围对结果解释造成影响。

6.2.2 对照组与消融实验设计

原正式实验设置 B0、B1、B2、B3 四个主要对照组及 A1—A4 四个消融组。

其中，B0 采用单次模型分析；B1 加入固定证据查询与混合知识检索；B2 采用具有有限工具调用能力的单调查者方案；B3 使用 EvidenceSOC 完整六角色协作流程。

消融实验以 B3 为基础，分别限制事件证据查询、禁用 RAG 知识增强、仅使用语义检索以及禁用验证能力，用于观察不同系统组件对调查结果的影响。所有实验遵循固定模型接口、案例顺序、上下文约束和工具调用预算，实验标签与评分答案独立保存在控制侧，不进入模型调查上下文。

6.2.3 评价指标

实验采用分类性能、回答覆盖、证据质量和资源开销等指标进行综合评价。

分类性能使用 Precision、Recall、F1 和 Accuracy 进行衡量。AIT 以固定六类 Macro F1 作为主要分类指标，DEDALE 以攻击正类 F1 作为主要指标。回答覆盖率用于衡量系统给出明确攻击或正常判断的案例比例。对于输出 unknown、失败或缺少有效诊断的案例，保留其在适用指标分母中的位置，不将未回答案例直接视为正确结果。

证据质量评价区分引用有效性和语义支持程度。前者检查 Evidence ID 与案件、来源及记录之间的合法关联；后者通过人工复核判断模型主张是否真正受到引用证据支持。

6.3 原正式实验结果与分析

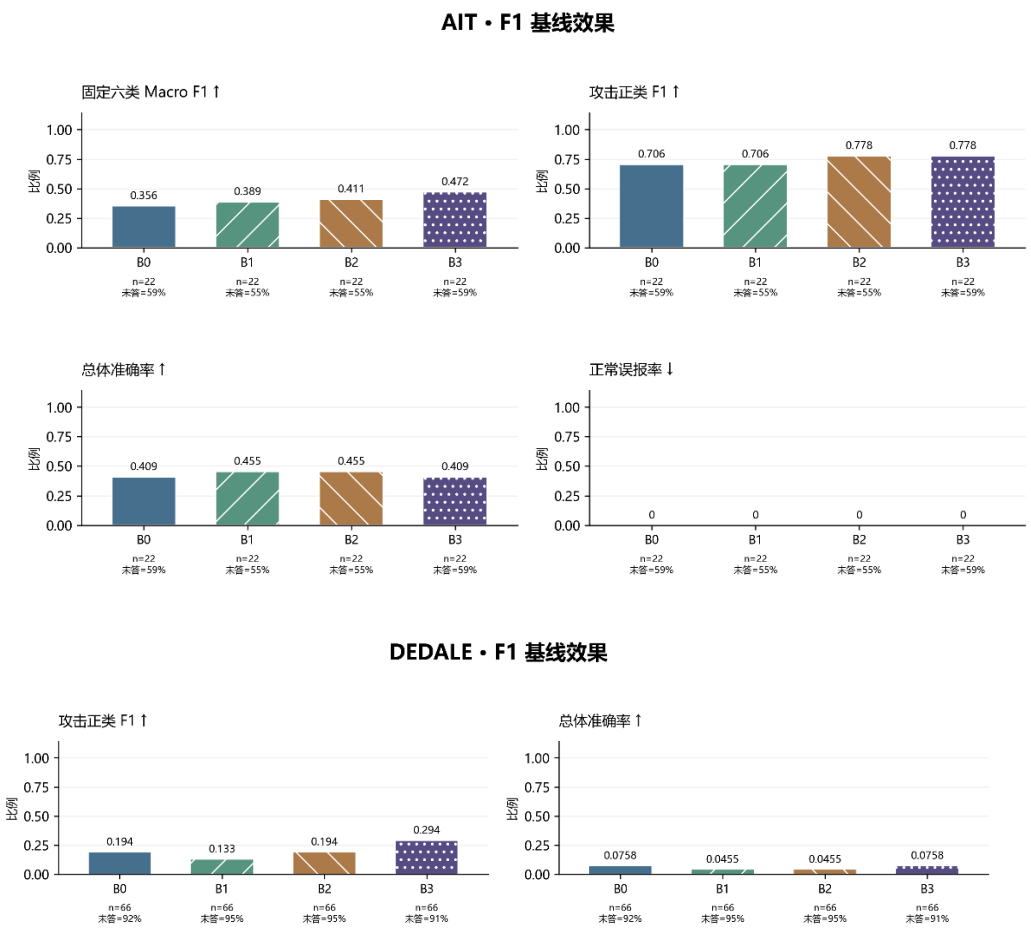
6.3.1 实验完成情况

原正式实验共登记 704 条“案例×实验组”记录，其中 AIT 数据集 176 条，DEDALE 数据集 528 条。最终全部记录获得执行终态，其中 638 条形成有效诊断，66 条执行失败。需要说明的是，有效诊断包括攻击、正常和 unknown 等合法输出，不代表模型完成了 638 次正确分类。所有失败和未知判断均保留在原始结果与评价分母中。

6.3.2 分类性能对比

原正式实验主要分类指标

实验组	AIT 六类 MacroF1	DEDALE 攻击正类 F1
B0	0.3556	0.1935
B1	0.3889	0.1333
B2	0.4111	0.1935
B3	0.4722	0.2941
A1	0.4722	0.1935
A2	0.4841	0.2500
A3	0.4722	0.3030
A4	0.4167	0.3030



从原始结果可以看出，完整六角色方案 B3 在 AIT 数据集上的固定六类 Macro F1 为 0.4722，高于 B2 的 0.4111；在 DEDALE 数据集上的攻击正类 F1 为 0.2941，高于 B2 的 0.1935。但是 B3 并未在全部消融组中取得最优表现。例如，AIT 的 A2 组 Macro F1 达到 0.4841，DEDALE 的 A3、A4 组正类 F1 达到 0.3030。因此，不能简单得出所有智能体组件均能稳定提高分类性能的结论。

AIT 固定六类评价还存在类别支持不均衡问题，其中 credential_attack 类别在冻结测试集中没有正类支持。在当前固定评分口径下，其理论 Macro F1 上限为 5/6，低于原设定的 0.85 目标。该问题属于评价目标与数据类别覆盖之间的结构性限制，补充支持类指标不能替代原始六类指标。DEDALE 未设置适用的六类分类金标，因此相关指标保持不适用状态（N/A）。

6.4 独立工程回归结果

6.4.1 工程回归实施情况

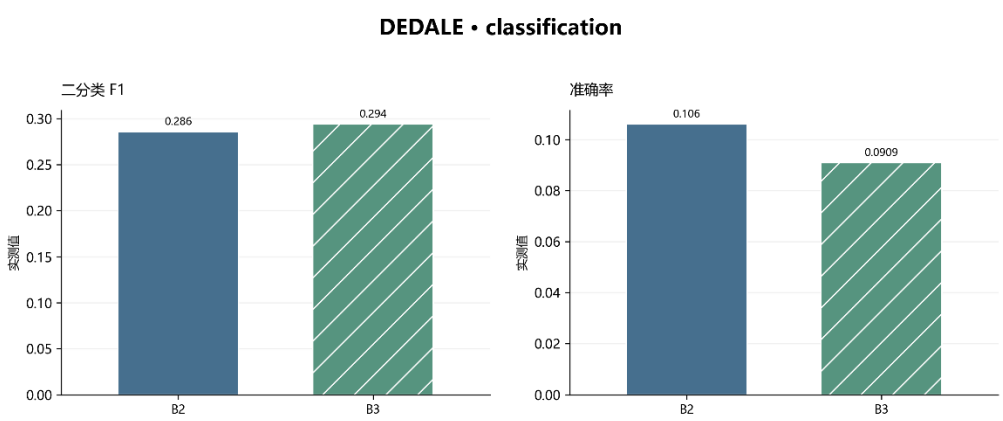
在原正式实验基础上，项目针对模型工具调用、证据校验、运行恢复和资源记录等工程问题进行了独立整改，采用新增的 regression-only 实验范围，使用原 88 个已见案例重新执行 B2/B3 两组，共 176 条回归记录。

本次回归采用独立的控制器与运行环境，实际结果由三个原生执行批次组成，分别覆盖 83、2 和 91 条记录。不同批次保留各自冻结的 worker 源码和运行记录，后续评分程序不改变原始实验执行身份。

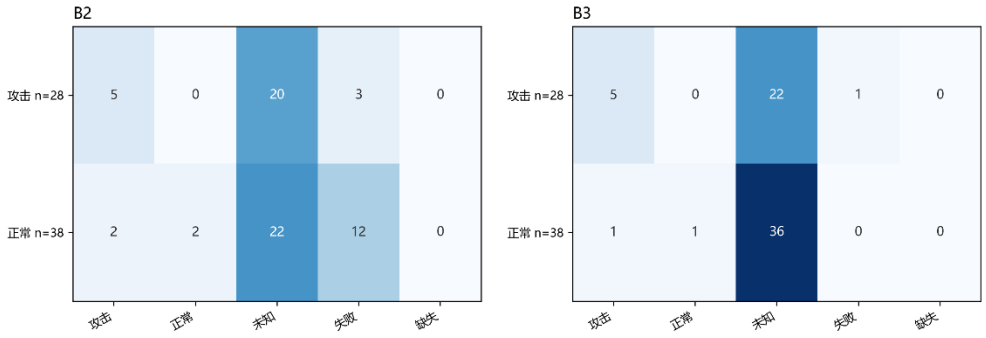
6.4.2 回归分类结果

新增 176 条工程回归分类结果

数据集/组别	完成/失败	主要 F1	回答覆盖率	正常 FPR
AIT/B2	21/1	0.3611	63.64%	0.00%
AIT/B3	21/1	0.3730	54.55%	0.00%
DEDALE/B2	51/15	0.2857	13.64%	5.26%
DEDALE/B3	65/1	0.2941	10.61%	2.63%



DEDALE · F6 二分类混淆矩阵（新176的B2/B3）



与原正式实验相比，新回归中 AIT/B2 与 AIT/B3 的回答覆盖率分别由 45.45%提高至 63.64%、由 40.91%提高至 54.55%，但对应六类 Macro F1 由 0.4111 和 0.4722 下降至 0.3611 和 0.3730。DEDALE/B2 的攻击正类 F1 由 0.1935 提高至 0.2857，B3 则基本保持 0.2941 不变

6.5 人工复核与证据质量评价

6.5.1 人工复核方案

为评价模型报告中事实性结论与引用证据之间的关系，项目采用预登记人工复核方案，对模型生成的事实主张和证据引用进行独立判断。

原正式实验归档 64 个人工复核槽位，其中 60 份报告包含事实性内容，4 份因原诊断失败无法形成事实报告。原复核共涉及 453 条事实性主张及 296 条引用。

新增工程回归另设置 16 个人工复核槽位，最终 15 份具有实际报告，R05 因无报告而客观不可复核。16 个槽位均得到相应处理，但不能视为 16 份均形成有效事实报告。

6.5.2 证据支持程度

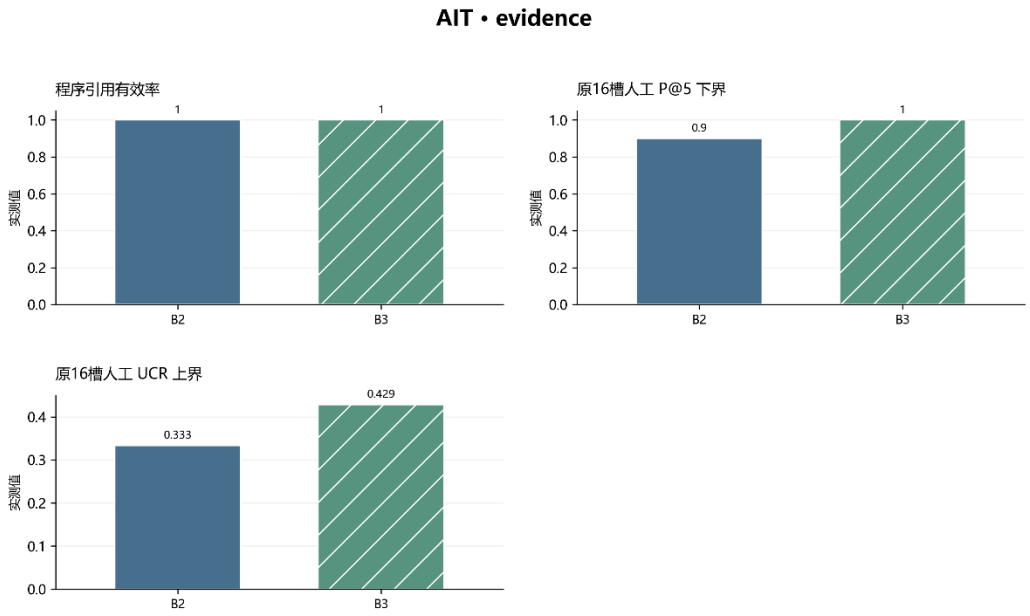
新回归人工复核共评价 131 条报告主张，其中 79 条获得支持、2 条不支持、47 条不确定、3 条无法判断。共检查 73 条证据引用，其相关性均被判断为相关。

需要区分的是，引用与主张相关并不意味着引用足以证明全部主张。事实支持程度仍需根据证据内容、观察范围和模型结论之间的逻辑关系进行判断。

为避免将不确定判断直接计为支持，项目使用不受支持主张比例的上下界描述人工评价结果。

新回归人工复核 UCR 结果

数据集/组别	审核主张数	UCR 下界	UCR 上界
AIT/B2	36	0.00%	33.33%
AIT/B3	49	2.04%	42.86%
DEDALE/B2	25	0.00%	52.00%
DEDALE/B3	21	4.76%	28.57%



UCR 下界依据明确不支持的主张计算，上界同时计入不确定及无法判断的主张。上述区间反映人工判断的不确定性边界，不属于统计置信区间。

6.6 系统工程测试与部署验证

6.6.1 功能与安全测试

除模型实验外，项目还对后端接口、受限 MCP 工具、审批流程、状态持久化及异常恢复机制开展工程验收。

截至目前冻结版本的历史验收已完成 909 项后端测试，失败、错误及跳过数量均为 0。七个关键代码包的语句覆盖率处于 91.31%—96.26%之间。

工程安全测试重点验证非法工具调用拒绝、跨案件访问控制、不可信观察内容处理、审批方案版本绑定及重复请求防护。同时针对 PostgreSQL 和 OpenSearch 服务中断、MCP 子进程异常、模型接口超时和服务重启等情况开展恢复测试。

这些测试验证了指定版本的程序约束与故障处理机制，但不代表真实供应商模型能够抵御全部提示注入，也不等于生产环境已经具备完整的企业级安全防护能力。

6.6.2 前端交互与状态恢复测试

目前冻结版本完成三轮串行生产浏览器测试，每轮 62 项均通过，覆盖调查工作台、响应审批、连接恢复及相关交互功能。测试包含真实本地服务流程和隔离模拟接口场景，模型运行主要采用 fixture 模式，不能将浏览器测试数量理解为真实大语言模型诊断次数。

6.6.3 系统性能与部署状态

在固定版本的本机测试环境中，首次 SSE 事件观测耗时为 59.1804 毫秒，但仅包含 1 次样本；告警列表和案件详情接口各进行 100 次请求，P95 延迟分别为 10.2453 毫秒和 22.8442 毫秒。

上述性能数据反映特定环境下的 API 与事件流响应情况，不能代表完整模型调查耗时、实际生产吞吐量或真实六分支验证性能。

系统采用 Next.js 前端与 FastAPI 后端分离部署方式，依赖 PostgreSQL、OpenSearch 及相应知识检索服务。历史工程验收已覆盖本地服务启动、数据库与索引交互、后端重启及状态恢复。

截至当前，尚无经过核实的公网在线演示地址及对应公网部署验收记录。因此，本报告仅说明已有的本机工程验证范围，不将其描述为已经完成公开生产部署。

第七章总结与展望

7.1 项目工作总结

本项目围绕安全运营中心在告警研判、证据关联和事件响应过程中面临的问题，设计并实现了 EvidenceSOC——基于证据链与多智能体协作的智能安全告警调查系统。

在系统架构方面，项目采用 Next.js、FastAPI、PostgreSQL 与 OpenSearch 构建前后端分离的安全调查平台，利用 LangGraph 组织告警分诊、证据收集、威胁分析、攻击链重构、响应决策和效果验证六角色工作流，实现调查状态管理、条件路由及过程审计。

在智能分析方面，系统将 DeepSeek 大语言模型与 MITRE ATT&CK 知识库、RAG 混合检索和受限 MCP 工具相结合，并通过 Evidence ID 证据引用、内容完整性校验及结构

化输出约束，将模型分析结果与实际安全事件建立可追溯关系。在响应环节，通过真实人工审批、方案版本绑定和模拟执行机制，实现受控的安全响应流程。

在实验与工程验证方面，项目完成原始 704 条正式实验记录及新增 176 条独立工程回归，形成分类性能、证据质量、资源消耗和人工复核等评价结果。指定冻结版本已完成 Task14 工程验收，验证了系统在接口调用、权限约束、状态恢复及异常处理等方面的实现情况。

总体而言，本项目构建了具有证据管理、有限自主取证和人工监督能力的智能安全调查原型，为研究大语言模型在安全运营场景中的受控应用提供了工程实践基础。

7.2 当前局限性

尽管系统已实现主要调查功能并完成阶段性工程验证，但仍存在以下不足。

首先，模型分类性能和回答覆盖率仍有改进空间。原正式实验与新增工程回归均存在较多 unknown 判断，部分数据集的分类指标未达到预设目标。工程修复改善了部分执行问题，但尚未证明分类效果能够在不同场景中稳定提升。

其次，实验范围与人工评价规模有限。新增回归使用原有已见案例，不能代表未见攻击场景下的泛化能力；人工复核主要依赖单名审阅人员和预登记样本，证据语义支持程度仍存在不确定性。

7.3 未来发展方向

后续研究将重点围绕调查质量、证据可信度和系统工程适用性进一步完善。

在智能调查方面，可在保留原实验结果和评价口径的基础上，研究更有效的证据查询策略、上下文组织方式及不确定性处理机制，减少无效工具调用，提高明确回答覆盖率，并通过新增独立未见案例检验系统泛化能力。

在证据质量方面，可进一步扩大人工复核样本，完善事实主张与证据引用之间的语义支持评价，并探索多审阅人一致性分析，使证据可信度评估更加充分。

在响应验证与工程应用方面，后续需要在满足实际审批、有效期和预算约束的前提下补充六分支计时与 F8 配对验证，进一步核验模拟响应效果。同时，完成当前前端与受测工程版本的整合测试，为系统后续扩展与实际应用研究奠定基础。

综上，EvidenceSOC 以证据约束为基础，将多智能体协作、知识增强分析与人工监督机制融入安全告警调查流程。项目的主要价值在于探索智能分析能力与确定性安全控制的结合方式，为构建更加可靠、可追溯和可审计的智能安全运营系统提供了可继续验证与完善的技术路径。